

Data Retention and Deletion Policy

Application: Personal Budget Application | **Owner:** Randall Miller (randallsm83@gmail.com) | **Version:** 1.0 | **Effective Date:** March 18, 2026 | **Review Cycle:** Annually

1. PURPOSE AND SCOPE

This policy defines the rules governing the retention, storage, and deletion of consumer financial data collected and processed by the Personal Budget Application ("the Application"), including data received from the Plaid API. It applies to all data stored in the Application's production database and associated infrastructure, and is reviewed on an annual basis or upon material changes to data handling practices.

2. DATA COLLECTED

The Application collects and stores the following categories of data from or on behalf of consumers:

- Account identifiers and balance information (via Plaid)
- Transaction records including date, amount, payee, and category
- Plaid access tokens (stored encrypted using AES-256-GCM)
- User authentication credentials (hashed passwords via bcrypt)
- User-entered budget and category data

3. RETENTION PERIODS

Data Type	Retention Period	Justification
Transaction records	Duration of active account	Required for budgeting functionality
Account & balance data	Duration of active account	Required for budgeting functionality
Plaid access tokens (encrypted)	Until bank connection is removed or account deleted	Required for ongoing sync; revoked on deletion

Data Type	Retention Period	Justification
Authentication credentials	Duration of active account	Required for user authentication
All user data	Deleted within 30 days of account deletion request	User right to deletion; privacy compliance

4. DATA DELETION PROCEDURES

Users may request deletion of their account and all associated data at any time. Upon receiving a deletion request, the following steps are performed within 30 days:

- All transaction records associated with the user are permanently deleted from the database.
- All account and budget data associated with the user are permanently deleted.
- Plaid access tokens are revoked via the Plaid API (`itemRemove`) and deleted from the database.
- User authentication credentials and profile data are permanently deleted.
- No data is archived or retained in backup systems beyond the 30-day deletion window.

5. SECURITY OF RETAINED DATA

- All data is stored in a Neon PostgreSQL database with encryption at rest.
- All data in transit is protected by TLS 1.2 or higher.
- Plaid access tokens are encrypted at rest using AES-256-GCM with a dedicated encryption key.
- Database access is restricted to the application server via authenticated connection strings stored as environment variables.

6. COMPLIANCE

This policy is designed to comply with applicable data privacy regulations including, but not limited to, the California Consumer Privacy Act (CCPA) and applicable provisions of the Gramm-Leach-Bliley Act (GLBA) as they pertain to personal financial data. The policy is reviewed annually and updated as required by changes in applicable law or data handling practices.

7. POLICY REVIEW

This policy is reviewed annually by the application owner. The review date and version number are updated upon each review. Material changes to data handling practices will trigger an immediate out-of-cycle review.

Next scheduled review: March 2027

Acknowledged and approved by:

Randall Miller

Signature

Randall Miller

Printed Name

March 18, 2026

Date